



ICT Risk Management Guideline

Version: 3.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Contents

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	5
2. Functional Scope and Target Groups	6
2.1. Functional scope of applicability.....	6
2.2. Target groups	6
2.3. Transition period	7
3. Definitions	8
3.1. Requirements	8
3.2. Explanation of requirements and key definitions	9
4. Requirements	10
4.1. Requirements	10
4.1.1. ICT Risk Governance.....	10
4.1.2. Context Establishment	18
4.1.3. ICT Risk Assessment.....	20
4.1.4. ICT Risk Treatment.....	23
4.1.5. ICT Risk Monitoring and Reporting	26
5. Roles and Responsibilities.....	33
5.1. Creator.....	33
5.2. Guideline Owner	33
6. Appendix	34
6.1. Contact Information.....	34
6.2. Document History	34
6.3. Related Written Rules	34
6.4. Abbreviations	35

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The ICT Risk Management Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	1. Have in place internal governance arrangements for ICT risk, including oversight for own subsidiaries that have adopted this policy.	4.1
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	3. Define the strategical objectives to manage ICT risks.	4.1
Govern	4. Develop and periodically review an ICT risk management system which ensures effective management of ICT risks and meets the protection goals.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Govern	10. Establish and maintain contact with relevant authorities.	4.1
Identify	2. Identify and record assets (e.g. data, hardware, software, systems, facilities, services, people) including respective interdependencies and classify these assets with their relative importance to organizational objectives (including security objectives) and the organization’s risk strategy.	4.2
Identify	4. Establish an ICT risk management process and perform ICT risk assessment on a regular basis and in the event of major changes, considering threats and vulnerabilities covering different IT assets (e.g. applications) and Non-IT assets (e.g.	4.2

	buildings, rooms) in a consistent way taking into consideration asset-specific differences in the assessment approach.	
Identify	5. Analyze relevant ICT risks in relation to third party relationships, taking into consideration the dependent functions and processes, and establish and agree appropriate safeguards.	4.2
Identify	6. Maintain a record of known ICT risks as input for a group-wide risk inventory.	4.2
Protect	1. Design and implement ICT Risk management control requirements to achieve the protection goals and integrating them to the ICT Written Rules Framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC¹, data management and other controls addressing poor administration and human error risks.	4.3
Detect	1. Define, implement, monitor, and regularly test detection processes and mechanisms to promptly detect anomalous activities including network performance issues and ICT-related incidents, and identify potential material single points of failure.	4.4
Respond	1. Define and activate response plans to quickly and effectively respond to ICT-related incidents and prevent further damage.	4.5
Learn and evolve	2. Independently review the organization's approach to manage ICT security and its implementation including people, processes, and technologies at planned intervals, or when significant changes occur.	4.7

¹ IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

Learn and evolve	3. Implement adaptive ICT risks management capabilities that learn and evolve with the dynamic nature of ICT risks.	4.7
Learn and evolve	4. Monitor relevant technological developments on a continuous basis to understand the possible impact on its digital operational resilience.	4.7
Learn and evolve	5. Regularly review compliance with the organization's ICT security policy, topic-specific policies, rules, and standards.	4.7
Communicate	1. Set out communication and crisis management actions to ensure that updated information is transmitted to all relevant internal staff and external stakeholders and reported to the competent authorities upon their request.	4.8

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG and/or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that owns ICT Risk Management topic

Table 2: Scope

2.2. Target groups

Within the scope of the current ICT Risk Management Guideline below is addressed the list of applicable target groups and operation areas²:

Target group	Key message
Management Body	The Management Body is responsible for ensuring awareness of the critical importance of ICT Risk Management in strategic decision-making and for overseeing the effective implementation of all arrangements related to the ICT Risk Framework. Within Deutsche Börse Group, this responsibility is operationally fulfilled by the relevant Executive Board — or equivalent senior management body at the Legal Entity level — which bears ultimate accountability for ICT Risk Management in accordance with this Policy. Accordingly, references to the Executive Board, Legal Entity Executive Board, or equivalent senior management roles throughout this Policy represent the concrete governance implementation of the Management Body function within the Deutsche Börse Group organizational and governance structure.
ICT Operational Management	To implement and maintain appropriate structures, processes, measures, and controls for the effective management of operations and risk (including internal control).

² For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

ICT Risk Oversight	To oversee, develop and keep updated the ICT Risk management strategy, policy, and practices. To provide complementary expertise, support, monitoring, and challenge related to the management of risk. To provide analysis and reports on the adequacy and effectiveness of risk management (including internal control).
Business Management	Leads and directs actions (including managing risk) and application of resources to achieve the objectives of the organization. To be accountable for the management of ICT-risks affecting their business function or process. To decide on risk treatment (accept, avoid or mitigate the risk).

Table 3: Target groups

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement>
Protection goals <Specifies the protection goal of the control requirement e.g., CIAA (Confidentiality, Integrity, Availability, Authenticity)>	Key references <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4. Requirements

4.1. Requirements

4.1.1. ICT Risk Governance

ID: 1 (version 3.0)	ICT Risk Framework and ICT Risk Management Framework
1 DOR.ICT.RMG.RIF.001	It must be ensured that an ICT Risk Framework is established as an integral part of the ICT Risk Management Framework.
1.1 DOR.ICT.RMG.RIF.002	A comprehensive ICT Risk Framework (which is part of the ICT Risk Management Framework) must be planned, established, implemented, maintained, and continually improved to align with legislative, regulatory, and contractual requirements, as well as best practices, international standards, business objectives, digital operational resilience strategy, legal entities' requirements, risk appetite, and the ICT Threat Landscape. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.1
1.2 DOR.ICT.RMG.RIF.003	The ICT Risk Management Framework must include at least strategies, policies, procedures, ICT protocols and tools that are necessary to duly and adequately protect Primary and Secondary Assets from ICT risks. This also encompasses domains outside the mandate of ICT risk, such as Third-Party Risk Management or Business Continuity Management. The ICT Risk Framework specifically includes documentation of policies, guidelines and procedures (incl. supporting documents). Asset-Types: Business Process Key References: DORA 2022/2554 A.6.1
1.3 DOR.ICT.RMG.RIF.004	The stakeholders (such as DBAG Group Risk Management and legal entity risk management function) defined in the ICT Risk Management Framework (including the ICT Risk Management Policy and ICT Risk Guidelines) must be identified and adequately involved and informed about the ICT Risk Management Framework. Asset-Types: Business Process Key References: DORA 2022/2554 A.14.2
1.4 DOR.ICT.RMG.RIF.005	The ICT Risk Management Framework must be reviewed and approved at least once a year and must additionally be reviewed and approved at least after the occurrence of a major ICT-related incident and following supervisory instructions or findings resulting from relevant digital operational resilience tests or audit procedures. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.5
1.5 DOR.ICT.RMG.RIF.006	The approach for monitoring, measuring, evaluating, and reporting of the ICT Risk Management Framework must be defined. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.1
1.6 DOR.ICT.RMG.RIF.007	A report on the review of the ICT Risk Management Framework must follow defined minimum requirements as outlined in Dora RTS Art. 27.2

	and must be submitted to the competent authority at its request in a searchable electronical format. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.5, DORA RTS RMF A.27.2
1.7 DOR.ICT.RMG.RIF.008	The ICT Risk Management Framework must be continuously improved based on the knowledge gained during implementation, monitoring, as well as from material changes, including changes to the cyber threat landscape, applicable legal obligations, ICT-related incidents and TLPTs, if relevant. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.5
1.8 DOR.ICT.RMG.RIF.009	The ICT Risk Management Framework must be subjected to regular internal ICT Risk Assurance assessments. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.6

ID: 2 (version 3.0)	Digital Operational Resilience Strategy
2 DOR.ICT.RMG.DOR.001	It must be ensured that a digital operational resilience (DOR) strategy is established, monitored and maintained supporting the business strategy and objectives.
2.1 DOR.ICT.RMG.DOR.002	The DOR strategy must include current and target capabilities to address digital operational resilience and attain respective objectives (measured through appropriate metrics), by establishing the risk tolerance level for ICT risk, in accordance with the risk appetite of legal entities. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8b), A.6.8c)
2.2 DOR.ICT.RMG.DOR.003	The DOR strategy must explain the ICT reference architecture including required changes to reach the objectives. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8d)
2.3 DOR.ICT.RMG.DOR.004	The DOR strategy must outline implemented mechanisms to detect ICT-related incidents (incl. major ICT-related incidents) to prevent their impact and explain, by measuring their effectiveness, how they provide appropriate protection. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8e), A.6.8f)
2.4 DOR.ICT.RMG.DOR.005	The DOR strategy must explain required changes to digital operational resilience testing and how it is implemented. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8g)
2.5 DOR.ICT.RMG.DOR.006	The DOR strategy must outline a communication strategy in the event of ICT-related incidents which are to be disclosed.

	Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8h)
2.6 DOR.ICT.RMG.DOR.007	The DOR strategy must include a procedure to monitor the execution and effectiveness of the strategy. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8
2.7 DOR.ICT.RMG.DOR.008	It must be ensured that changes to the business strategy, IT strategy and the DOR strategy are considered when developing, documenting, and implementing ICT Risk Management processes, policies, guidelines and procedures. Asset-Types: Business Process Key References: DORA RTS RMF A.3f)
2.8 DOR.ICT.RMG.DOR.009	The DOR strategy must explain how the ICT Risk Management Framework supports the business strategy and objectives of DBAG or the respective legal entity. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8a)
2.9 DOR.ICT.RMG.DOR.010	The evolution of ICT risks and ICT-related incidents (incl. cyber-attacks) must be analyzed over time, considering relevant metrics (e.g. frequency, types, magnitude) or patterns to deepen the understanding of the risk exposure, especially with regards to critical or important functions, and to improve the DOR. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8
2.10 DOR.ICT.RMG.DOR.011	The current DOR situation must be evident based on the number of reported major ICT-related incidents and the effectiveness of preventive measures. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8
2.11 DOR.ICT.RMG.DOR.012	The management body must be responsible for approving the DOR strategy. Asset-Types: Business Process Key References: DORA 2022/2554 A.5.2 d)

ID: 3 (version 3.0)	Target Protection Requirements
3 DOR.ICT.RMG.TPR.001	It must be ensured that control requirements in the ICT Risk Guidelines are properly defined and correspond to the protection need.
3.1 DOR.ICT.RMG.TPR.002	Control requirements must be formulated to reflect the asset criticality with regard to any of the protection goals, legislative statutory, regulatory and contractual requirements, as well as their role in supporting critical or important functions (CIF). Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.8.1

ID: 4 (version 3.0)	Information classification																																			
4 DOR.ICT.RMG.INC.001	It must be ensured that information classification is performed and documented properly according to pre-defined criteria.																																			
4.1 DOR.ICT.RMG.INC.002	Information classification must reflect the highest classification value separately for each security objective of confidentiality, integrity, availability, and authenticity. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203; §8a (1) BSIG 9 MAS TRMG 3.3.1																																			
4.2 DOR.ICT.RMG.INC.003	The classification process, criteria and classification results should be aligned with the business impact analysis methodology and process as well as the CIF process. It must consider the impact classification according to the table below. <table><tr><th>Type of Impact</th><th>Critical</th><th>Major</th><th>Minor</th><th>Negligible</th></tr><tr><td>Financial</td><td>Very high financial losses up to the existential threat to the business foundations.</td><td>High financial losses with a substantial, but non-existential threat</td><td>Tangible losses</td><td>Minor losses</td></tr><tr><td>Public confidence</td><td>Affected for a long period</td><td>Affected for a medium period</td><td>Affected for a short period</td><td>Affected below 1 month</td></tr><tr><td>Media or Reputation</td><td>Extensive international media broadening in popular newspapers, TV, and radio</td><td>International coverage in most international newspapers, TV, and radio</td><td>Media broadening in one or a few national or international newspapers</td><td>Negative report in local media</td></tr><tr><td>Market</td><td>Harmful market reaction and significant market movement longer than 1-2 weeks</td><td>Harmful market reaction and significant market movement between 1 day to 1-2 weeks</td><td>Market irritation and undesirable movements for one day</td><td>No remarkable impact</td></tr><tr><td>Personal Data (PD)</td><td>Very high / high risk PD processing</td><td>Increased Risk PD processing (exceptions)</td><td>Normal PD processing</td><td>No PD processing</td></tr><tr><td>Regulatory impact</td><td>Significant fines, special regulatory supervision / investigation, or complete loss of license</td><td>Potential fines or other regulatory actions</td><td>Verbal or written comments</td><td>No actions with respect to regulations</td></tr></table> Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.9	Type of Impact	Critical	Major	Minor	Negligible	Financial	Very high financial losses up to the existential threat to the business foundations.	High financial losses with a substantial, but non-existential threat	Tangible losses	Minor losses	Public confidence	Affected for a long period	Affected for a medium period	Affected for a short period	Affected below 1 month	Media or Reputation	Extensive international media broadening in popular newspapers, TV, and radio	International coverage in most international newspapers, TV, and radio	Media broadening in one or a few national or international newspapers	Negative report in local media	Market	Harmful market reaction and significant market movement longer than 1-2 weeks	Harmful market reaction and significant market movement between 1 day to 1-2 weeks	Market irritation and undesirable movements for one day	No remarkable impact	Personal Data (PD)	Very high / high risk PD processing	Increased Risk PD processing (exceptions)	Normal PD processing	No PD processing	Regulatory impact	Significant fines, special regulatory supervision / investigation, or complete loss of license	Potential fines or other regulatory actions	Verbal or written comments	No actions with respect to regulations
Type of Impact	Critical	Major	Minor	Negligible																																
Financial	Very high financial losses up to the existential threat to the business foundations.	High financial losses with a substantial, but non-existential threat	Tangible losses	Minor losses																																
Public confidence	Affected for a long period	Affected for a medium period	Affected for a short period	Affected below 1 month																																
Media or Reputation	Extensive international media broadening in popular newspapers, TV, and radio	International coverage in most international newspapers, TV, and radio	Media broadening in one or a few national or international newspapers	Negative report in local media																																
Market	Harmful market reaction and significant market movement longer than 1-2 weeks	Harmful market reaction and significant market movement between 1 day to 1-2 weeks	Market irritation and undesirable movements for one day	No remarkable impact																																
Personal Data (PD)	Very high / high risk PD processing	Increased Risk PD processing (exceptions)	Normal PD processing	No PD processing																																
Regulatory impact	Significant fines, special regulatory supervision / investigation, or complete loss of license	Potential fines or other regulatory actions	Verbal or written comments	No actions with respect to regulations																																
4.3 DOR.ICT.RMG.INC.004	Information classification must be proportionately reflected in protection level and respective control requirements must be defined for the respective Information and related Secondary Assets.																																			

	Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.9
4.4 DOR.ICT.RMG.INC.005	The cost of appropriately protecting the information based on its classification must not be a consideration in the process of classifying the asset. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.9
4.5 DOR.ICT.RMG.INC.006	Primary and Secondary Asset (IT and non-IT Assets) classification must be documented before the start of the asset usage and accessible to relevant stakeholders, e.g., Information Owners, Asset Owner, Project Leads. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.9
4.6 DOR.ICT.RMG.INC.007	The adequacy of the information classification and any relevant documentation must be reviewed at least yearly and should be reviewed at the latest when risk assessment is performed. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.1

ID: 5 (version 3.0)	Critical or important functions
5 DOR.ICT.RMG.CIF.001	It must be ensured that all critical or important functions and their supporting assets are identified.
5.1 DOR.ICT.RMG.CIF.002	Procedures to identify critical or important functions must be in place. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.1
5.2 DOR.ICT.RMG.CIF.003	Critical or important functions must be identified and documented according to the specific criteria of the legal entities. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.1
5.3 DOR.ICT.RMG.CIF.004	Primary and Secondary Assets supporting critical or important functions must be identified and documented together with their roles and dependencies in relation to ICT risk to provide context for the classification of information. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.1
5.4 DOR.ICT.RMG.CIF.005	The identification of critical or important functions must be carried out at least annually. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.1

ID: 6 (version 3.0)	ICT Risk Management Methodology
------------------------	---------------------------------

6 DOR.ICT.RMG.MTH.001	It must be ensured that an ICT Risk Management Methodology is in place considering an ICT Risk Profile as input for the ICT Risk Management lifecycle.
6.1 DOR.ICT.RMG.MTH.002	An ICT Risk Management Methodology must be defined, operationalized, and implemented to specify the ICT Risk Management Processes, including ICT risk assessment and the flow of ICT risk information. Asset-Types: Business Process Key References: DORA 2022/2554 A5.2d)
6.2 DOR.ICT.RMG.MTH.003	ICT Risk Management Methodology must consider the pre-defined ICT Risk Profile and include a measurement mechanism for the ICT risk level (considering the ICT Threat Landscape, Threat Events and Risk Categories). Asset-Types: Business Process Key References: DORA 2022/2554 A4.1
6.3 DOR.ICT.RMG.MTH.004	ICT Risk Management Methodology must define guidance for the ICT Risk Management procedures on mechanisms to integrate information regarding the ICT Risk Profile (specifically threat insights) in the ICT risk management processes. Asset-Types: Business Process Key References: DORA RTS RMF A.1

ID: 7 (version 3.0)	ICT Risk Management Processes
7 DOR.ICT.RMG.PRC.001	It must be ensured that ICT Risk Management processes are in place to identify, assess, treat, monitor, and report ICT risks.
7.1 DOR.ICT.RMG.PRC.002	ICT Risk Management processes (incl. tools) must be designed and implemented to ensure that the risks are adequately managed and within the defined risk appetite and tolerance level. Asset-Types: Business Process Key References: DORA RTS RMF A.3.c)
7.2 DOR.ICT.RMG.PRC.003	ICT Risk Management processes must reflect the ICT Risk Management Methodology (incl. consideration of an ICT Risk Profile which includes Risk Taxonomy, ICT Threat Landscape, ICT Risk Categories, etc.) and address managing of information security and information technology and other ICT-related risks (incl. facilities, people, and suppliers). Asset-Types: Business Process Key References: DORA 2022/2554 A4.1, A4.2
7.3 DOR.ICT.RMG.PRC.004	Risk acceptance criteria based on risk appetite as well as evaluation criteria and impact criteria must be defined. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2
7.4 DOR.ICT.RMG.PRC.005	All Primary (Information Assets, Process Assets) and Secondary Assets (IT and non-IT Assets) and control requirements must be part of the ICT Risk Management processes.

	Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2
7.5 DOR.ICT.RMG.PRC.006	Appropriate ICT systems, protocols and tools must be used for managing ICT risks and related procedures and processes. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.3
7.6 DOR.ICT.RMG.PRC.007	As part of the ICT Risk Management processes, relevant technological developments must be continuously monitored and their impact on the ICT risks, control requirements and digital operational resilience must be considered. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.7

ID: 8 (version 3.0)	ICT Risk Management Roles and Responsibilities
8 DOR.ICT.RMG.RAR.001	It must be ensured that roles and responsibilities regarding ICT Risk Management and the resulting duties are defined, documented, and operated.
8.1 DOR.ICT.RMG.RAR.002	Staff responsible for designing, managing, and operating the ICT Risk Management Framework must have the necessary skills and competence, gained through proper education, training, or experience, or be under the proper supervision of experienced staff to ensure effective ICT Risk management, IT and business operations, and IT compliance. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.7.2
8.2 DOR.ICT.RMG.RAR.003	Clearly separated roles and responsibilities considering the three lines of defense model or similar must be assigned for ICT-related functions such as for ICT Risk Oversight and ICT Operational Management, ensuring an appropriate level of independence between the roles to avoid conflict of interest. Asset-Types: Business Process Key References: DORA 2022/2554 A.5.2c), A.6.4
8.3 DOR.ICT.RMG.RAR.004	When outsourcing tasks to verify compliance with ICT Risk management requirements, whether internally or externally, DBAG or the respective legal entity remains fully accountable. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.10
8.4 DOR.ICT.RMG.RAR.005	An Information Owner and Asset Owner must be responsible to manage, monitor, protect and oversee information assets or IT and non-IT Assets throughout their entire lifecycle, ensuring the roles are identified, classified, maintained, and updated annually or in case of any changes. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection,

	Supplier, Building, Room, Datacenter Key References: ISO 27001:2022 Cor 202203 A.5.9
8.5 DOR.ICT.RMG.RAR.006	An Information Owner must ensure assessment and treatment of ICT risks for Primary and Secondary Assets throughout their entire lifecycle. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.

ID: 9 (version 3.0)	Control Governance
9 DOR.ICT.RMG.GOV.001	It must be ensured that all control requirements from ICT Risk Guidelines are fully addressed by controls, control ownership is assigned, controls are documented, and evidence from performed controls is in place³.
9.1 DOR.ICT.RMG.GOV.002	Each control must be documented in relevant documents (e.g. Policies, Guidelines, Processes, Procedures, ICS or other supporting documentation aimed at addressing all aspects of control requirements). Asset-Types: Business Process Key References: ISO/IEC 27001:2022 A.5.35
9.2 9.3 DOR.ICT.RMG.GOV.003	Evidence of performed controls must be in place and available upon request. Each control must have clearly defined ownership and be assigned to one Control Owner. Where this is not practicable, ownership may be assigned to multiple Control Owners. • Asset-Types: Business Process Key References: ISO/IEC 27001:2022 A.5.36

³ As required by ICT Risk Management Policy within Chapter 4.1

4.1.2. Context Establishment

ID: 10 (version 3.0)	ICT Risk Profile, ICT Threat Landscape and Risk Categories
10 DOR.ICT.RMG.RTL.001	It must be ensured that an ICT Risk Profile, including ICT Threat Landscape, and ICT Risk Categories are in place.
10.1 DOR.ICT.RMG.RTL.002	An ICT Risk Profile must be in place, including a collection of at least the following documentation, along with the links between these documents: The Risk Taxonomy, particularly the identification of the ICT-related Risk Clusters and relevant Risk Items (Level 4), the Risk Appetite for ICT risks (including Tolerance Levels), the ICT Threat Landscape, and ICT-related Operational Risk Scenarios (incl. results). Asset-Types: Business Process Key References: CSDR Art. 45.1; DORA RTS RMF A.3ei), A.3eii), A.3eiii); ISO/IEC 27001;2022 C.6.1.2, C.8.2, A.5.36; MAS TRMG 3.2.2, 4.1.4, 4.2.1
10.2 DOR.ICT.RMG.RTL.003	ICT-related entries in the Risk Taxonomy must be defined and operationalized based on external factors (e.g. industry best practices, external threat intelligence, regulatory requirements, etc.) and internal factors (e.g. business needs, risk appetite, internal threat intelligence). Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8a)
10.3 DOR.ICT.RMG.RTL.004	The ICT-related risk appetite and tolerance levels must be defined and approved as part of the overall risk appetite and tolerance levels of DBAG, respectively the legal entities and in relation to the Risk Taxonomy. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8b)
10.4 DOR.ICT.RMG.RTL.005	The ICT-related entries to the Risk Taxonomy, ICT Threat Landscape, ICT Risk Categories, risk appetite and tolerance levels must be reviewed in defined intervals, at least annually. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8b)
10.5 DOR.ICT.RMG.RTL.006	An ICT Threat Landscape must be defined, refined, and implemented based on the pre-defined Risk Taxonomy and specifically identifying ICT threats to the Group Level. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2
10.6	The ICT Threat Landscape must be maintained and regularly updated, include industry standard and knowledge bases, and shared with relevant stakeholders. The ICT Threat Landscape also must provide a risk-based view, which then motivates content and prioritization of ICT Control Framework and ICT Key Controls, respectively. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2

10.7 DOR.ICT.RMG.RTL.011	ICT threats must be monitored and classified with a rating of high significance where all of the following conditions are met: Asset-Types: Business Process Key References: CSDR Art. 45.1; DORA RTS RMF A.3ei), A.3eii), A.3eiii); ISO/IEC 27001;2022 C.6.1.2, C.8.2, A.5.36; MAS TRMG 3.2.2, 4.1.4, 4.2.1
10.7.1 DOR.ICT.RMG.RTL.012	The threat, if occurred, could affect or could have affected critical or important functions of DBAG or related legal entities (including third-party providers, clients, or financial counterparts) based on available information. Asset-Types: Business Process Key References: CSDR Art. 45.1; DORA RTS RMF A.3ei), A.3eii), A.3eiii); ISO/IEC 27001;2022 C.6.1.2, C.8.2, A.5.36; MAS TRMG 3.2.2, 4.1.4, 4.2.1
10.7.2 DOR.ICT.RMG.RTL.013	legal The threat has a high probability of occurrence at DBAG or related entities and must take into account at least the following elements: - The capabilities and intent of threat actors to the extent known by DBAG or related legal entities. - The persistence of the threat and any accrued knowledge about ICT-related incidents that have impacted DBAG or related legal entities or its third-party provider, clients, or financial counterparts. - The geographical spread of the areas at risk • Asset-Types: Business Process Key References: CSDR Art. 45.1; DORA RTS RMF A.3ei), A.3eii), A.3eiii); ISO/IEC 27001;2022 C.6.1.2, C.8.2, A.5.36; MAS TRMG 3.2.2, 4.1.4, 4.2.1
10.8 DOR.ICT.RMG.RTL.014	Insights from digital resilience testing, real-life ICT-related incidents (particularly cyber-attacks), challenges in executing ICT continuity and recovery plans, and information shared with counterparts during reviews must be consistently integrated in the ICT Threat Landscape and ICT Risk Categories. Asset-Types: Business Process Key References: DORA 2022/2554 A.13.3
10.9 DOR.ICT.RMG.RTL.015	ICT Risk Categories with a scenario description must be defined, refined, and operationalized based on the ICT Threat Landscape. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8b)
10.10 DOR.ICT.RMG.RTL.016	ICT Risk Categories must be mapped to an ICT Threat Landscape and include information of related control requirements as well as Primary and Secondary Assets with a focus on those supporting critical or important functions (CIF). Asset-Types: Business Process Key References: DORA 2022/2554 A.6.8b)
10.11 DOR.ICT.RMG.RTL.017	Relevant changes to the ICT Risk Profile must be monitored and reported to the ICT Risk Management Methodology owner while significant changes must be reported to the Management Body of DBAG and the legal entity, including the LE CISOs. Asset-Types: Business Process Key References: DORA RTS RMF A.3.e.i), A.3e.iii)

4.1.3. ICT Risk Assessment

ID: 11 (version 3.0)	ICT Risk Assessment
11 DOR.ICT.RMG.RAS.001	It must be ensured that the ICT Risk Assessment with ICT Risk Identification, Analysis and Evaluation is performed with sufficient resources, clearly defined responsibilities, and relevant risk data.
11.1 DOR.ICT.RMG.RAS.002	Associated roles and responsibilities for the ICT Risk Assessment must be defined. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
11.2 DOR.ICT.RMG.RAS.003	ICT risk assessment must be performed on all legacy ICT Systems at least annually and additionally before and after connecting them to new IT Assets to ensure no new risks are introduced. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.7
11.3 DOR.ICT.RMG.RAS.004	The ICT risk assessments of the affected Primary and Secondary Assets including the ICT risk treatment measures, if implemented, must be re-performed at least annually and in any of the following cases: - Increase of the asset's criticality - New or stricter control requirement associated with the asset in the ICT Risk Guidelines - Significant change with a security impact - In case of special requests by third party or regulator - Before the go-live - Major change in the network and information system infrastructure, in the processes or procedures affecting their ICT supported business functions, information assets or ICT system assets • Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2, DORA Art. 8.3

ID: 12 (version 3.0)	ICT Risk Identification
12 DOR.ICT.RMG.RID.001	It must be ensured that ICT risks relevant to the organization are properly identified.
12.1 DOR.ICT.RMG.RID.002	An ICT risk identification process must be established to identify potential ICT risks. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.2
12.2 DOR.ICT.RMG.RID.003	The identification of internal and external vulnerabilities and threats, particularly exposure to and from other financial entities, related to all relevant ICT supported business functions, Primary, and Secondary Assets must be conducted continuously. Risks (including linkage to ICT Threats) related to all relevant ICT supported business functions, Primary,

	and Secondary Assets must be at least annually. Monitoring of changes that could affect the ICT risk profile must enable their prompt detection. ● Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2, DORA Art. 8.2
--	--

ID: 13 (version 3.0)	ICT Risk Analysis
13 DOR.ICT.RMG.RAN.001	It must be ensured that all identified ICT risks are analyzed.
13.1 DOR.ICT.RMG.RAN.002	An ICT risk analysis process must be in place to determine and analyze identified ICT risks based on their likelihood of occurrence and their potential impact. Asset-Types: Business Process Key References: DORA RTS RMF A.3b.i)
13.2 DOR.ICT.RMG.RAN.003	The impact on DBAG or legal entities that might result from identified control requirement deviations considering the impact on loss of confidentiality, integrity, availability or authenticity of the assets and business impact such as financial, reputational, compliance impact or privacy violation must be assessed. Asset-Types: Business Process Key References: DORA RTS RMF A.3b.ii)
13.3 DOR.ICT.RMG.RAN.004	The likelihood of exploitation of identified control requirement deviations considering threats and vulnerabilities must be assessed. Asset-Types: Business Process Key References: DORA RTS RMF A.3b)
13.4 DOR.ICT.RMG.RAN.005	As a result of the ICT risk analysis process, the ICT risk level based on impact and likelihood must be determined. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2
13.5 DOR.ICT.RMG.RAN.006	Qualitative and quantitative indicators to measure impact and likelihood of OpRisk scenarios based on ICT Threat Events, Risks, and vulnerabilities must be developed. Asset-Types: Business Process Key References: DORA RTS RMF A.3.b.ii)

ID: 14 (version 3.0)	ICT Risk Evaluation
14 DOR.ICT.RMG.REV.001	It must be ensured that identified ICT risks are evaluated, analyzed and prioritized.
14.1 DOR.ICT.RMG.REV.002	An ICT Risk Evaluation process must be in place to evaluate the analyzed ICT risks resulting in a respective ICT risk level. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2

14.2 DOR.ICT.RMG.REV.003	The risk must be determined and evaluated for all control requirement deviations considering impact and likelihood. The ICT risk level may take values: Very low (R1), Low (R2), Medium (R3), High (R4) <table><tr><th> Impact Likelihood </th><th>High</th><th>Medium</th><th>Low</th><th>Very Low</th></tr><tr><th>High</th><td>R4</td><td>R4</td><td>R3</td><td>R3</td></tr><tr><th>Medium</th><td>R4</td><td>R3</td><td>R3</td><td>R2</td></tr><tr><th>Low</th><td>R3</td><td>R3</td><td>R2</td><td>R2</td></tr><tr><th>Very Low</th><td>R3</td><td>R2</td><td>R2</td><td>R1</td></tr></table> Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2	Impact Likelihood	High	Medium	Low	Very Low	High	R4	R4	R3	R3	Medium	R4	R3	R3	R2	Low	R3	R3	R2	R2	Very Low	R3	R2	R2	R1
Impact Likelihood	High	Medium	Low	Very Low																						
High	R4	R4	R3	R3																						
Medium	R4	R3	R3	R2																						
Low	R3	R3	R2	R2																						
Very Low	R3	R2	R2	R1																						
14.3 DOR.ICT.RMG.REV.004	The ICT risks must be (re)evaluated in annual cycles, including a review of the effectiveness of implemented ICT risk treatment measures. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2																									
14.4 DOR.ICT.RMG.REV.005	The ICT Risk Evaluation process must consider the ICT Risk Categories to categorize the resulting ICT Risk. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.2																									
14.5 DOR.ICT.RMG.REV.006	If the implemented ICT risk treatment measures prove to be ineffective, further ICT risk treatment must be performed. Asset-Types: Business Process Key References: DORA 2022/2554 A.8.2																									

4.1.4. ICT Risk Treatment

ID: 15 (version 3.0)	ICT Risk Treatment
15 DOR.ICT.RMG.RTR.001	It must be ensured that ICT risks are adequately treated.
15.1 DOR.ICT.RMG.RTR.002	An ICT risk treatment process must be in place to manage and respond to identified ICT risks. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.2 DOR.ICT.RMG.RTR.003	ICT risk treatment plans must be created, documented, and maintained. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.3 DOR.ICT.RMG.RTR.004	The ICT risk treatment plans must be signed off for all identified ICT risks by the respective Information Owner. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.4 DOR.ICT.RMG.RTR.005	The ICT risk treatment plan must include, at a minimum, the following information: - Selected treatment option including actions for implementation - Rationale for the selection of the treatment options, including the expected benefits to be attained - Responsible and accountable stakeholder for approving the treatment plan and implementing the plan Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.5 DOR.ICT.RMG.RTR.006	Information Owners should be prepared to demonstrate and provide updates on the status of implementation of the ICT risk treatment plan when required. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.6 DOR.ICT.RMG.RTR.007	All identified ICT risks must be assigned to one of the following treatment options as part of the ICT risk treatment plan: Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.6.1 DOR.ICT.RMG.RTR.008	“Accept” – acceptance of risk without mitigation (risks in scope for KRITIS assets must not be accepted if state-of-the-art mitigating measures are available and their use is appropriate). Risk acceptance is only possible for the remaining residual risk. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.6.2 DOR.ICT.RMG.RTR.009	“Mitigate” – implementation of mitigating measures to reduce the ICT risk level. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3

15.6.3 DOR.ICT.RMG.RTR.010	“Avoid” – elimination of activities and exposures that can negatively affect Primary and Secondary Assets of the legal entities. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.7 DOR.ICT.RMG.RTR.011	Selecting ICT risk treatment options must be based on clearly defined criteria which align with the organization's risk appetite (specified in underlying Procedure documentation). To set criteria, the following should be considered: - The nature and type of uncertainties that can affect outcomes and objectives (both tangible and intangible) - How consequences and likelihood will be defined, predicted, and measured - Time-related factors - Consistency in the use of measurements - How the level of risk will be determined - How combinations and sequences of multiple risks will be taken into account - The organization's capacity Asset-Types: Business Process Key References: DORA RTS RMF A.31.1a)
15.8 DOR.ICT.RMG.RTR.012	The decision for ICT risk acceptance must be based on the defined risk acceptance criteria. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2
15.9 DOR.ICT.RMG.RTR.013	Mitigating measures to reduce the ICT risks must be implemented in accordance with a defined ICT risk treatment plan. The risk mitigation timeline starts as soon as the risk has been assessed by the asset owner and timelines are defined as follows: - High (R4): 3 months - Medium (R3): 6 months - Low (R2): 12 months - Very low (R1): 18 months Asset-Types: Business Process Key References: DORA RTS RMF A.3cb), A.3cc)
15.10 DOR.ICT.RMG.RTR.014	Information Owner may decide on different timelines (shortened / extended) in case a proper justification is available and documented. In any case, the ICT risks must be (re)evaluated in annual cycles (please refer to 14.3). Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
15.11 DOR.ICT.RMG.RTR.015	The identified risks, related decisions, and information as well as the mitigating measures of the treatment plan, measure owners, agreed due dates and other related information such as the status from monitoring the ICT risk treatment plan must be documented in the risk registries. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2
15.12 DOR.ICT.RMG.RTR.016	After performing the ICT risk treatment, it must be assessed whether the risk tolerance levels of DBAG or the respective legal entity have been attained.

	Asset-Types: Business Process Key References: DORA RTS RMF A.3cb), A.3cc)
15.13 DOR.ICT.RMG.RTR.017	In case the defined risk tolerance levels cannot be attained through the implemented measures, the risk treatment plan must be revised and corrective actions to improve the ICT risk treatment measures must be documented. Asset-Types: Business Process Key References: DORA RTS RMF A.3cb), A.3cc)

ID: 16 (version 3.0)	Residual Risk Handling
16 DOR.ICT.RMG.RRH.001	It must be ensured that residual ICT risks that remain after the ICT risk treatment has been performed are handled appropriately.
16.1 DOR.ICT.RMG.RRH.002	A process to identify and determine residual ICT risks must be in place. Asset-Types: Business Process Key References: DORA RTS RMF A.3d)
16.2 DOR.ICT.RMG.RRH.003	It must be ensured that residual ICT risks (e.g., in cases of risk acceptance) are identified and registered in an inventory, along with an acknowledgment of the residual ICT risk and an explanation for their acknowledgement. Asset-Types: Business Process Key References: DORA RTS RMF A.3d.iii)
16.3 DOR.ICT.RMG.RRH.004	Acknowledged residual ICT risks must be reviewed at least annually including: - Identification of changes to residual risks - Assessment of existing mitigation measures - Assess if the reasons for accepting the residual risks are still valid Asset-Types: Business Process Key References: DORA RTS RMF A.3d.iv), A.3d.iv.1), A.3d.iv.2), A.3d.iv.3)
16.4 DOR.ICT.RMG.RRH.005	If the residual risks have changed, the implemented mitigation measures are no longer sufficient, or the reasons for accepting the residual risks are no longer valid, causing the residual risks to exceed the defined risk tolerance levels, a new ICT risk treatment must be performed. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
16.5 DOR.ICT.RMG.RRH.006	Decisions on the acceptance and the review of residual ICT risks must be performed by Information Owners. • Asset-Types: Business Process Key References: ICT Risk Framework 1.0

4.1.5. ICT Risk Monitoring and Reporting

ID: 17 (version 3.0)	ICT Risk Monitoring and Reporting
17 DOR.ICT.RMG.RMR.001	It must be ensured that ICT risks and related information are adequately communicated to the relevant stakeholders such as the Management Body.
17.1 DOR.ICT.RMG.RMR.002	The reporting to relevant stakeholders and decision makers (incl. Management Body) must take place with an aggregation appropriate to their roles and responsibilities related to ICT Risk management. Asset-Types: Business Process Key References: ISO/IEC 27001:2022 Cor 202203 C.6.1.3
17.2 DOR.ICT.RMG.RMR.003	ICT risks identified as part of, and the results of ICT risk assessments, including the status of the ICT risk treatment plans must be communicated to the relevant stakeholders and decision makers up to the Management Body for review. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2
17.3 DOR.ICT.RMG.RMR.004	Identified ICT risks and relevant key indicators (e.g. risk appetite and tolerance levels, digital operational resilience metrics, etc.) must be reported regularly to: - Appropriate stakeholders, including the ICT Risk Oversight and ICT Operational Management at least quarterly, at least monthly in case of R3 risks and immediately in case of identification of R4 risks - The affected Management Body and LE CISOs at least quarterly and within a month in case of identification of R4 risks Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
17.4 DOR.ICT.RMG.RMR.005	All ICT risks must be registered in inventories which must be updated continuously and establish a monitoring and review process for continuous assessment and treatment of risks. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.3
17.5 DOR.ICT.RMG.RMR.006	ICT risks with the highest ICT risk level must be assigned top priority and monitored closely with regular reporting on the actions that have been taken to mitigate them. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.6.1.2
17.6 DOR.ICT.RMG.RMR.007	The fulfillment of ICT Risk control requirements must be documented for all Primary and Secondary Assets via ICT Risk documentation (e.g., ICT Risk, Security Documentation (SD) or similar). Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.31
17.7 DOR.ICT.RMG.RMR.008	Senior ICT staff must report at least yearly to the management body and LE CISOs on the following observations: • - digital operational resilience testing,

	- real life ICT-related incidents, - cyber-attacks, - challenges faced upon the activation of ICT business continuity plans, and - challenges faced upon the ICT response and recovery plans. Asset-Types: Business Process Key References: DORA Art. 13.3, DORA Art. 13.5
--	---

ID: 18 (version 3.0)	Independent ⁴ ICT Internal Controls Monitoring and Risk Assurance
18 DOR.ICT.RMG.CMR.001	It must be ensured that internal controls are monitored, ICT risk assurance is provided, and control effectiveness validated and reported to appropriate stakeholders such as Information and Asset Owners, executive boards of the legal entities.
18.1 DOR.ICT.RMG.CMR.002	Established and implemented ICT internal controls must be continuously monitored and validated to ensure that these controls are valid and effective. Asset-Types: Business Process Key References: DORA RTS RMF A.3a)
18.2 DOR.ICT.RMG.CMR.003	Observations on the effectiveness of controls must be reported to control owners. Asset-Types: Business Process Key References: DORA RTS RMF A.3a)

ID: 19 (version 3.0)	ICT Risk Management Continuous Improvement
19 DOR.ICT.RMG.IMP.001	It must be ensured that lessons learned on the activities performed as part of an ICT Risk Management processes are captured and continuously used for improvement.
19.1 DOR.ICT.RMG.IMP.002	It must be ensured that the ICT Risk Management processes (incl. tool definitions, etc.) are reviewed and improved to be up to date with latest best practices and tailored to the needs of DBAG or the respective legal entity. Asset-Types: Business Process Key References: ICT Risk Framework 1.0
19.2 DOR.ICT.RMG.IMP.003	Independent reviews of ICT Risk Management processes and the implementation thereof must be performed and if necessary, corrective actions should be initiated. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 C.9.1.2
19.3 DOR.ICT.RMG.IMP.004	Where appropriate, the results of monitoring technological developments must be used to update ICT Risk Management processes (incl. tools) and effectively combat ICT risk (e.g. cyberattacks). Asset-Types: Business Process Key References: DORA 2022/2554 A.13.7
19.4 DOR.ICT.RMG.IMP.005	A follow-up process and rules for the timely verification and remediation of critical ICT-related audit findings must be established. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.7

⁴ Independent means in this case that the activities are carried out by individuals independent of the area under review ensuring there is no conflict of interest, and a separation of duties is maintained.

19.5 DOR.ICT.RMG.IMP.006	The results of monitoring ICT Internal controls and the effectiveness of implemented ICT risk treatment measures must be used to correct and improve those measures. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.5
19.6 DOR.ICT.RMG.IMP.007	ICT Risk management tools must be regularly reviewed and updated accordingly with the improvements to ICT Risk Management and related procedures and processes. Asset-Types: Business Process Key References: DORA RTS RMF A.3f.a), A.3f.b) A.3f.c)
19.7 DOR.ICT.RMG.IMP.008	The ICT-related Operational Risk Scenarios must be reviewed on a regular basis, at least annually. Asset-Types: Business Process Key References: DORA 2022/2554 A.6.5, A.6.7, A.8.2, A.13.7

ID: 20 (version 3.0)	Provisions on Telecommunication Network and Services
20 DOR.ICT.RMG.TKG.001	It must be ensured that provisions for the telecommunication network and services, including relevant registration and responsibilities, are properly managed.
20.1 DOR.ICT.RMG.TKG.002	A security officer⁵ must officially be nominated and contact details provided to the Bundesnetzagentur. Asset-Types: Business Process Key References: TKG §166
20.2 DOR.ICT.RMG.TKG.003	The telecommunication network and telecommunication services must be registered at the Bundesnetzagentur. Asset-Types: Business Process Key References: TKG §166

ID: 21 (version 3.0)	Digital Operational Resilience Testing Programme
21	It must be ensured that a sound and comprehensive Digital Operational Resilience Testing (DORT) Programme is established, maintained, and reviewed as an integral part of the ICT Risk Management Framework.
21.1	A DORT Programme must be established, documented, and maintained within the ICT Risk Management Framework. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(1)

⁵ The role originates from the German Telecommunications Act (TKG), which refers to a "Sicherheitsbeauftragter", which has been translated to "security officer" in relation to the responsibilities outlined in the TKG.

21.2	The DORT Programme determine a suitable set of tests in a risk-based approach, such as vulnerability assessments and scans, open source analyses, network security assessments, gap analyses, physical security reviews, questionnaires and scanning software solutions, source code reviews where feasible, scenario-based tests, compatibility testing, performance testing, end-to-end testing, penetration testing, and threat-led penetration testing (TLPT). Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(2)
21.3	The DORT Programme must follow a risk-based approach, taking into account: the evolving ICT risk landscape and ICT Threat Landscape as defined in ID 10, the proportionality principle with regard to the size and overall risk profile of the legal entity, the criticality of information assets and services provided, and the involvement of ICT third-party service providers. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(3)
21.4	The DORT Programme must define, for each testing type covered under 21.2: the applicable scope and asset coverage, the minimum frequency of execution, the methodology and approach to be applied, the independence requirements for testers, and the owning guideline or procedure containing the detailed technical specifications, if not already determined by the test owners. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(4)
21.5	The DORT Programme must define a programme lifecycle comprising: Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(1)
21.5.1	Establish: Formal creation of the programme with defined scope, governance structure, resource allocation, and management body approval. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(1)
21.5.2	Maintain: Ongoing monitoring of programme execution, coverage tracking against the full test type inventory, and integration of new or changed testing requirements arising from changes to the ICT Threat Landscape, regulatory requirements, or the DOR strategy. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(1)
21.5.3	Review: Formal annual review of the programme's completeness, effectiveness, and alignment with DORA Art. 24(1), triggered additionally by: occurrence of a major ICT-related incident, supervisory instructions or findings, material changes to the legal entity's ICT environment or critical or important functions, and major risks from TLPT exercises. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(1)
21.6	Roles and responsibilities for the DORT Programme must be clearly defined and documented, including: – The LE must designate a DORT Programme owner at appropriate seniority level responsible for programme governance, coordination across owning guidelines, and reporting to the management body.

	– A clear allocation of responsibility for each testing type to the relevant guideline, procedure and operational responsibility for the execution of tests. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 5(2)(d)
21.7	The DORT Programme must establish a centralized programme register that: – Inventories all testing types with their defined scope, frequency, methodology reference, and owning guideline. – Tracks the execution status of all planned tests against the programme schedule, including completion dates, responsible parties, and any deviations from planned frequencies. – Records all findings identified across all testing types, their severity classification, remediation status, and linkage to the ICT risk register maintained under ID 17.4. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(5)
21.8	The results of all testing activities conducted under the DORT Programme must be integrated into the ICT Risk Management processes as follows: – Testing findings must be forwarded continuously into the ICT risk identification and assessment processes defined in ID 12 and ID 13, and must inform updates to the ICT Threat Landscape maintained under ID 10.8. – Testing findings that identify control deficiencies must trigger ICT risk treatment actions in accordance with ID 15, with remediation timelines aligned to the risk level determined under ID 14. – Lessons learned from testing activities, including TLPT exercises, real-life ICT-related incidents, and challenges in executing ICT continuity and recovery plans, must be incorporated into the DORT Programme review process defined in 21.5.3 and into the DOR strategy maintained under ID 2. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(5)
21.9	DORT programme must report annually to the management body and LE CISOs covering as a minimum: – The overall execution status of the programme against the planned schedule, including any deviations and their justification. – A summary of findings identified across all testing types, their severity distribution, and the status of remediation actions. – An assessment of the effectiveness of the programme in identifying weaknesses in the legal entity's digital operational resilience. – Planned changes to the programme for the upcoming period, including any new testing types, scope expansions, or methodology updates. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 13(5)
21.10	The DORT Programme must ensure non-duplication and consistency across the framework by: – Maintaining a clear mapping between each testing type and the single owning guideline or procedure containing its detailed technical specifications and execution requirements, avoiding conflicting requirements across guidelines

	– Establishing a coordination mechanism between the DORT Programme owner and the operational owners of all referenced guidelines to ensure alignment upon any changes to testing requirements, frequencies, or methodologies. Asset-Types: Business Process Key References: DORA 2022/2554 Art. 24(1)
--	--

5. Roles and Responsibilities

5.1. Creator

The creator of the ICT Risk Management Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of ICT Risk Management Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the ICT Risk Management Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the ICT Risk Management Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact ICT Risk Governance & Advisory in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	28.01.2026	Material update
3.0	19.08.2026	Annual update with material changes

Coordination before publication

Version	Date	Task	Name
3.0	24.05.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	22.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	22.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
3.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	n/a

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
